

Cuidados de Implementacion

PyME Financing Platform

Objetivo del documento

Checklist tecnico para implementar el sistema sin romper la logica del diseno de base de datos: permisos, validaciones, archivos, estados, calculos, matching, auditoria y pruebas.

1. Checklist ejecutivo

Area	Cuidado principal
Autenticacion y roles	Separar claramente internal_operator y applicant. El applicant solo ve sus propios datos.
Propiedad de empresa	companies.applicant_user_id puede ser nulo para flujo interno, pero si existe applicant debe usarse para filtrar acceso.
Estados de solicitud	Controlar transiciones validas; no permitir saltos como draft -> matched.
Documentos locales	Guardar archivos en carpeta local y solo metadatos/ruta en BD. Validar tipo, tamano, hash y permisos.
Analisis de riesgo	No calcular si faltan datos financieros, deuda confirmada, documentos minimos o snapshot de entrada.
Matching financiero	Generar recomendaciones ligadas a risk_assessment_id, no solo a application_id.
Auditoria	Registrar acciones importantes, pero no guardar password_hash, tokens ni contenido de documentos.

2. Usuarios, roles y acceso

Regla central

La seguridad no depende solo de ocultar botones en el frontend. Toda restriccion debe validarse tambien en el backend antes de consultar, crear, actualizar o eliminar datos.

Rol	Permisos esperados
internal_operator	Puede ver todas las solicitudes, registrar empresas, revisar documentos, ejecutar analisis, generar matching y administrar productos/reglas.
applicant	Puede registrar/editar su empresa, crear solicitudes, cargar documentos y consultar estado/resultados de sus propias solicitudes.

Operacion	Validacion requerida
GET /companies	internal_operator ve todas; applicant solo las asociadas a applicant_user_id.
GET /applications/:id	Validar que el applicant sea propietario de la empresa relacionada.
POST /risk-assessments	Solo internal_operator.
POST /matches	Solo internal_operator y solo si existe analisis valido.
PATCH /documents/:id/review	Solo internal_operator.
POST /documents/:id/upload	applicant propietario o internal_operator.

3. Propiedad de datos y flujo interno

Campo	Uso correcto
companies.applicant_user_id	Puede ser NULL cuando el operador registra una empresa sin cuenta de solicitante.
companies.created_by_user_id	Registra quien capturo la empresa. No sustituye al propietario.
financing_applications.created_by_user_id	Registra quien creo la solicitud.
application_documents.uploaded_by_user_id	Registra quien subio el archivo.
application_documents.reviewed_by_user_id	Registra quien aprobo o rechazo el documento.

Cuidado

No confundas propiedad con captura. Un operador puede capturar una empresa, pero eso no significa que sea el propietario de la empresa.

4. Estados de solicitud

Estado	Significado
draft	Solicitud creada, aun editable.
documents_pending	Faltan documentos o hay documentos rechazados.
ready_for_analysis	Documentacion minima completa y datos financieros listos.
analyzed	Ya existe al menos un risk_assessment.
matched	Ya existen recomendaciones asociadas al ultimo analisis.
closed	Caso cerrado. Evitar ediciones criticas sin reabrirlo.

Transicion valida	Condicion
draft -> documents_pending	Cuando se crea o inicia checklist documental.
documents_pending -> ready_for_analysis	Solo si documentos minimos y datos obligatorios estan completos.
ready_for_analysis -> analyzed	Solo despues de calcular riesgo.
analyzed -> matched	Solo despues de generar recomendaciones.
matched -> closed	Cuando el caso queda concluido.

5. Validaciones condicionales obligatorias

Caso	Regla
Deuda	Si has_existing_debt = true, existing_debt_amount > 0 y monthly_debt_payment > 0. Si es NULL, no calcular riesgo.
Facturas	Si se evaluara factoraje, has_invoices debe estar confirmado; no asumir false si no se capturo.
Garantia	Si has_collateral = true, collateral_type y collateral_estimated_value son obligatorios.
Documento uploaded	Debe existir file_path, stored_filename, mime_type, file_size_bytes, file_hash_sha256, uploaded_by_user_id y uploaded_at.
Documento approved/rejected	Debe existir reviewed_by_user_id y reviewed_at.
RFC	Validar longitud segun business_type: persona moral 12 caracteres, PFAE 13 caracteres.
Montos y porcentajes	No permitir valores negativos; risk_score, compatibility_score y document_completion_percentage entre 0 y 100.

6. Manejo local de documentos

Regla de almacenamiento

El archivo se guarda localmente; la base de datos solo guarda metadatos y ruta. Nunca guardar PDFs o imagenes como binarios dentro de la BD para este MVP.

Aspecto	Cuidado
Ruta segura	Usar carpetas por solicitud: uploads/applications/{application_id}/...
Nombre seguro	No usar directamente el nombre original como nombre almacenado. Generar stored_filename seguro.
Tipos permitidos	PDF, JPG, PNG u otros definidos. Rechazar ejecutables o archivos desconocidos.
Tamano maximo	Definir limite por archivo y validarlo antes de guardar.
Hash SHA-256	Guardar file_hash_sha256 para detectar duplicados o cambios inesperados.
Permisos	Un applicant no debe poder descargar documentos de otra solicitud.

7. Analisis de riesgo y matching

Elemento	Cuidado
input_snapshot	Debe guardar los datos usados para calcular el riesgo. Sin esto, el historial pierde contexto.
rule_set_version	Guardar version de reglas usada para explicar por que un calculo salio asi.
risk_assessments	Cada recalcu lo crea un nuevo registro; no sobrescribir historial.
application_matches	Debe apuntar a risk_assessment_id. Cada analisis puede tener sus propias recomendaciones.
estimated_annual_rate_used	Guardar la tasa usada en cada match porque puede variar por producto.
estimated_monthly_payment	Calcular por producto recomendado, no solo a nivel de solicitud.
debt_service_coverage_ratio	Calcular considerando deuda actual + pago estimado del producto.

Nota de alcance

El sistema debe presentarse como pre-evaluacion y recomendacion de productos, no como aprobacion final de credito real.

8. Reglas de producto

Parte	Cuidado
financial_products	Define características y requisitos mínimos del producto: monto, antigüedad, tasa estimada, documentos requeridos.
product_rules	Define scoring de compatibilidad: suma o resta puntos según datos de la solicitud.
condition_value	Aunque se guarde como texto, el backend debe convertir a número, boolean o enum según rule_field.
score_weight	Mantener límites controlados; evitar pesos exagerados que generen scores incoherentes.
is_active	Desactivar reglas antiguas en lugar de borrarlas para no romper historial.

9. Auditoria y datos sensibles

Tema	Cuidado
Que auditar	Cambios de estado, revision documental, creacion/edicion de productos, ejecucion de analisis, generacion de matching.
Que no auditar completo	password_hash, tokens, contenido de documentos, datos sensibles completos si no es necesario.
old_values/new_values	Guardar solo campos relevantes o valores enmascarados cuando aplique.
application_status_history	Usarlo para historial de negocio visible de la solicitud.
audit_logs	Usarlo para trazabilidad tecnica interna.

10. Edicion y eliminacion

Elemento	Politica
financial_products	No borrar si ya tiene matches o reglas. Usar is_active = false.
product_rules	No borrar en uso normal. Editar o desactivar.
document_requirements	No borrar si ya se uso en solicitudes. Desactivar.
companies	Evitar borrar si tiene solicitudes. Para MVP, mejor no implementar borrado.
financing_applications	Evitar borrado si ya tiene documentos, analisis, matches o historial.

11. Pruebas minimas antes de considerar estable

Prueba	Resultado esperado
Permisos	Un applicant no puede ver ni editar solicitudes de otro applicant.
Estados	No se permiten transiciones invalidas.
Documentos	No se acepta aprobar un documento sin reviewed_by_user_id y reviewed_at.
Riesgo	No se calcula riesgo si faltan datos obligatorios o has_existing_debt esta NULL.
Matching	No se generan recomendaciones sin risk_assessment_id valido.
Archivos	Rechazar archivos no permitidos, demasiado grandes o con nombre inseguro.
Auditoria	Las acciones importantes crean audit_log sin exponer password_hash ni tokens.
Historial	Un recalcuulo crea nuevo risk_assessment y nuevos matches asociados.

12. Orden recomendado de implementacion

Fase	Implementar
1	Autenticacion basica, users y roles.
2	Empresas y solicitudes con permisos por rol.
3	Catalogos: document_requirements, financial_products, product_rules.
4	Carga local de documentos y validaciones de archivo.
5	Maquina de estados de solicitud.
6	Analisis de riesgo con input_snapshot.
7	Matching de productos por risk_assessment_id.
8	Expediente digital y dashboard.
9	Audit logs y pruebas de seguridad.

Anexo de Actualización

PyME Financing Platform

Documento base conservado: Cuidados de Implementación

Este anexo no reemplaza ni resume el documento base. El contenido original se conserva íntegro. Las reglas de este anexo se agregan al diseño y prevalecen cuando una regla anterior sea ambigua o use lenguaje de sugerencia.

A. Decisiones confirmadas para todos los documentos

Decisión	Instrucción obligatoria
Registro de applicant	El applicant debe poder crear su propia cuenta desde una ruta pública usando, como mínimo, fullName, email y password. El sistema debe asignar el rol applicant automáticamente.
Resultado visible para applicant	El applicant no debe ver el análisis interno completo, risk_score, pesos de reglas, DSCR detallado, audit_logs ni comparación interna de productos. Solo debe ver la decisión final publicada por el operador.
Operación interna	El internal_operator debe ver risk_assessments, application_matches, razones internas, porcentajes, indicadores financieros y debe crear/publicar la decisión final.
Corrección de necesidad	El internal_operator debe poder validar o corregir la necesidad declarada por el applicant mediante validated_need_type antes de generar matching o decisión final.
Documentos rechazados	Cuando el applicant suba nuevamente un documento rechazado, el sistema debe reemplazar el archivo en el mismo application_document, actualizar metadatos, cambiar status a uploaded y registrar audit_log.
Auditoría	El sistema debe auditar solo acciones sensibles; no debe registrar absolutamente todos los cambios ni guardar secretos, tokens, password_hash o contenido de documentos.

B. Regla de redacción para implementación

Toda frase del documento base que use “recomendado”, “sugerido”, “podría” o “si se implementa” debe interpretarse como instrucción obligatoria cuando describa una regla del MVP, una validación de seguridad, una entidad de base de datos, un endpoint crítico, una transición de estado o una prueba mínima.

C. Cuidados agregados de implementación

Área	Instrucción obligatoria
Registro público	Implementar POST /auth/register para crear usuarios applicant. Validar email único, password fuerte, hash seguro y usuario activo.
Resultado al applicant	Crear una capa de decisión publicada. El applicant no consulta risk_assessments ni application_matches directamente.
Corrección de necesidad	Implementar validated_need_type y registrar quién validó, cuándo y por qué.
Matching	Usar COALESCE(validated_need_type, need_type). Penalizar o descartar productos incoherentes con el uso real del dinero.
Decisión	El operador debe elegir una opción o marcar not_prequalified / needs_more_information antes de publicar.
Documento rechazado	La nueva carga reemplaza el archivo en el mismo registro, cambia status a uploaded, limpia revisión anterior y audita el reemplazo.
Auditoría	Auditar registro, login, creación/edición crítica, revisión documental, reemplazo documental, cálculo de riesgo, matching, decisión y publicación.